铁路计算机应用
RAILWAY COMPUTER APPLICATION

基于Docker的网络安全靶场设计与实现

梁建辉，侯昱辉，刘润福，何靖刚，李志强

Network security shooting range based on Docker

LIANG Jianhui, HOU Yuhui, LIU Runfu, HE Jinggang, and LI Zhiqiang

引用本文:
梁建辉, 侯昱辉, 刘润福, 等. 基于Docker的网络安全靶场设计与实现[J]. 铁路计算机应用, 2022, 31(11): 67–70.
LIANG Jianhui, HOU Yuhui, LIU Runfu, et al. Network security shooting range based on Docker [J]. Railway Computer Application, 2022, 31(11): 67-70.

在线阅读 View online: http://tljsjyy.xml-journal.net/2022/I11/67

您可能感兴趣的其他文章

Articles you may be interested in

铁路网络安全靶场设计与研究
Design and research on railway network shooting range
铁路计算机应用. 2021, 30(8): 52–56

铁路网络安全攻防仿真实验平台方案设计
Scheme of railway network security attack and defense simulation experiment platform
铁路计算机应用. 2020, 29(3): 51–54,59

铁路网络攻防靶场平台方案研究
Research on solution to attack and defense range platform for railway network
铁路计算机应用. 2021, 30(6): 58–62

基于自适应安全的铁路网络安全框架设计研究
Railway network security framework based on adaptive security
铁路计算机应用. 2020, 29(8): 6–10

基于改进Apriori算法的铁路网络安全预警方法研究
Railway network security early warning method based on improved Apriori algorithm
铁路计算机应用. 2021, 30(3): 59–64

铁路网络安全防护策略研究
Railway network security protection strategy
铁路计算机应用. 2021, 30(11): 11–14

关注微信公众号，获得更多资讯信息

文章编号：1005-8451（2022）11-0067-04

基于 Docker 的网络安全靶场设计与实现

梁建辉，侯昱辉，刘润福，何靖刚，李志强
（中国铁路兰州局集团有限公司　信息技术所，兰州　730000）

摘　要：为进一步提高铁路职工网络安全意识和攻防技能水平，文章采用 Docker Swarm 集群和动态独立靶机技术，设计网络安全靶场。该靶场具有快速部署、快速恢复、易扩容的特点，可用于日常的网络安全学习、竞赛及仿真环境渗透测试，已在中国铁路兰州局集团有限公司上线使用。使用结果表明，该靶场在培养铁路站段网络安全人才、提升铁路网络安全“人防”水平等方面发挥了重要作用。

关键词：铁路网络安全靶场；仿真环境；容器化；渗透测试；攻防演练
中图分类号：U29 : TP393　**文献标识码：**A　**DOI：**10.3969/j.issn.1005-8451.2022.11.14

Network security shooting range based on Docker

LIANG Jianhui, HOU Yuhui, LIU Runfu, HE Jinggang, LI Zhiqiang
(Institute of Information and Technology, China Railway Lanzhou Group Co. Ltd., Lanzhou　730000, China)

Abstract: In order to further improve the network security awareness and attack and defense skills of railway workers, this paper used Docker Swarm cluster and dynamic independent target technology to design a network security shooting range. The shooting range was characterized by rapid deployment, rapid recovery and easy expansion. It can be used for daily network security learning, competition and simulation environment penetration testing, and has been put into use in China Railway Lanzhou Group Co. Ltd. The application results show that the shooting range has played an important role in training network security talents in railway stations and depots and improving the level of "civil air defense" of railway network security.

Keywords: railway network security shooting range; simulation environment; containerization; penetration test; offensive and defensive drill

近年来，铁路信息网络受到的外部攻击量不断增长，安全形势日益严峻，对运输生产安全造成潜在威胁。国家“十四五”规划和 2035 年远景目标纲要[1]提出了建设数字中国的方针，建设智能铁路，全面加强网络安全体系和保障能力建设[2]。高速铁路大规模建设以来，我国铁路装备的智能化和信息化程度越来越高，新技术的应用及大量的互联网出口，使得铁路网络环境越来越复杂化、多样化、边界模糊化，铁路网络安全环境面临着严峻挑战。铁路作为重要的交通基础设施，信息化程度较高，也是网络攻防战中被攻击的重点目标之一，面向铁路的攻击方式也从单一的扫描渗透攻击转为复杂的高级持续性威胁（APT，Advanced Persistent Threat）攻击[3]。

网络安全靶场是进行新型网络攻击技术检验、网络安全竞赛、网络安全人才培养的重要工具。美国早于 2008 年发布了关于开展“国家网络安全靶场”项目研发工作的通知，并同时启动国家赛博靶场建设项目[4]。2016 年美国白宫公布了《网络安全国家行动计划》，再次对网络基础设施水平、专业人才队伍建设等 5 个方面作出全面提升[5]。而我国的网络安全靶场产业发展与国际水平还存在差异，国内一些科研机构及高校建立了一些满足特定需求的网络安全靶场[6-7]，但尚缺少面向铁路行业的网络安全靶场。

为此，本文基于 Docker 技术，设计了集网络安全竞赛、仿真渗透测试、网络安全人才培养等功能为一体的网络安全靶场。

1　靶场设计

1.1　总体架构

网络安全靶场采用容器化分布式架构，遵循分层设计理念，将板块设计细化为数据资源层、功能

收稿日期：2022-09-09
基金项目：中国铁路兰州局集团有限公司科技研究开发计划课题（2022073-2）
作者简介：梁建辉，高级工程师；侯昱辉，助理工程师。

实现层及应用代理层，如图 1 所示。

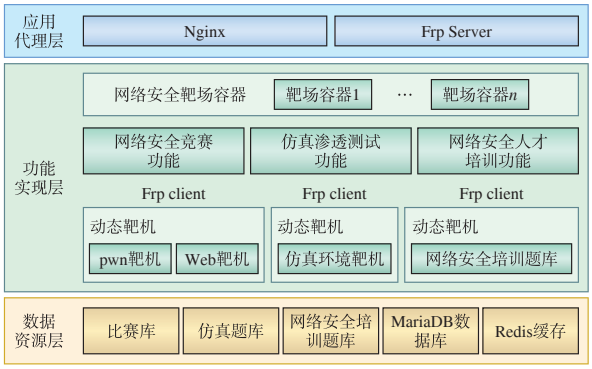

图1　网络安全靶场总体架构

1.1.1　数据资源层

数据资源层内容包括比赛库、网络安全培训题库、仿真题库、MariaDB 及 Redis 缓存 5 部分，数据资源采用容器方式实现。其中，MariaDB 用于存储用户的登录信息、答题信息、积分排行榜及靶场配置信息等；Redis 用于缓存用户登录凭证、动态靶机的 ID 及端口号等，为不需要频繁更新的数据提供缓存服务，从而加快靶场响应时间，提升用户使用体验。

1.1.2　功能实现层

网络安全靶场、动态靶机及 Frp Client 是功能实现的关键组件，均以容器方式运行，可充分发挥容器轻量级、快速部署、快速恢复、易扩容的优势。其中，网络安全靶场通过使用传输层安全协议加密的 Docker 应用程序接口连接 Docker Swarm 集群，控制动态靶机的生成与销毁；动态靶机底层环境使用 Docker Swarm 集群，通过 Frp Client 程序将靶机端口进行映射，实现在网站前端点击按钮，即可生成用户专属靶机，避免因共享环境而影响用户使用体验，可提高网络安全比赛时公平性，同时方便后续扩展 Swarm 集群节点，提升靶场整体性能。

1.1.3　应用代理层

该层主要负责靶场与用户间的交互。多个网络安全靶场容器通过 Nginx 做反向代理负载均衡，使用 IP Hash 负载均衡算法来分配用户所访问到的靶场容器，并利用 Nginx 缓存静态资源，在一定程度上增加吞吐量、提高靶场可用性并提升靶场响应时间。

不同角色用户通过 Web 页面登录、访问靶场，可得到不同的靶场使用权限。Frp 用于反向代理，包括服务器端 Frp Server 和客户端 Frp Client。应用代理层中的 Frp Server 通过与功能实现层中各类型靶机的 Frp Client 程序连接，以反向代理的方式，可使不同子域名或用同一 IP 的不同端口访问到对应的靶机。

1.2　网络环境部署

网络安全靶场网络环境部署如图 2 所示。

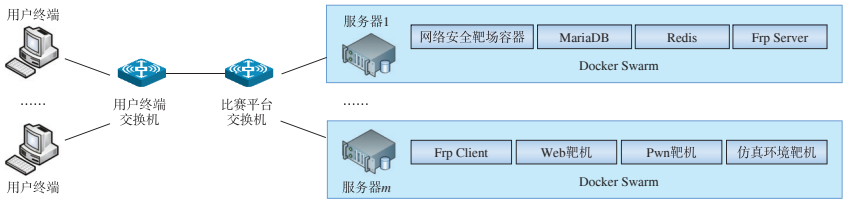

图2　网络安全靶场网络环境部署

用户通过终端交换机可直接与网络安全靶场实现网络互通。由于服务器底层均采用 Docker Swarm 技术，因此搭建网络安全靶场的服务器数量不受限制，后续可根据用户数量动态扩展节点，提高靶场同时在线用户数。服务器 1 主要运行网络安全靶场平台、MariaDB、Redis、Frp Server 4 种类型的容器，用于搭建靶场网站，网络安全靶场容器直接映射网站端口提供服务。其余服务器主要用于运行 Frp Client 容器及给用户下发动态靶机，3 种类型的动态靶机通过 Frp Client 与服务器 1 上的 Frp Server 相连接，通过 Frp 程序反向代理动态靶机，用户即可通过服务器 1 的不同端口号访问对应靶机。

1.3　靶场功能

基于 Docker 的网络安全靶场可实现以下功能。

（1）网络安全竞赛功能。该靶场可作为夺旗赛（CTF，Capture The Flag）平台，采用动态独立靶机技术，每道动态靶机题目被开启后，会自动生成一个虚拟题目环境，并为每个用户生成一个独一无二

的 Flag，可防止作弊行为。当题目完成后，用户可将动态靶机销毁，网络安全靶场会快速释放动态靶机所占系统资源，以便其他用户快速生成动态靶机。

（2）仿真环境渗透测试功能。通过添加仿真环境容器镜像，可快速生成仿真环境动态靶机；通过对仿真环境靶机的渗透测试和反复攻击，可提升网络信息系统相关人员的实战技能水平；根据对仿真环境靶机的渗透测试，发现铁路系统中可能存在的安全漏洞和风险，找到铁路安全防护中的短板，可优化防御策略，提高相关人员的网络安全防御能力和意识。

（3）网络安全人才培训功能。靶场可作为日常网络安全理论知识及网络安全实操的学习平台，为不同水平、不同类型的用户提供难度逐步进阶的课程及实操环境，使其逐步掌握网络安全的理论知识、实操技能及攻防技战法，从而提高铁路行业网络安全人才的培养效能。

2　关键技术

2.1　Docker 容器网络

Docker 使用 Linux 虚拟网络技术，Docker 中的每个网络接口默认都是虚拟的接口。容器之间要相互通信的前提是两者必须有属于同一个网络的网卡。网络安全靶场中所有关键模块及动态独立靶机均以 Docker 容器的形式存在，容器之间资源是相互隔离的。靶场使用 Docker 容器网络控制动态独立靶机及各容器之间的连通与隔离，使用 Docker Compose 定义和运行多容器网络。

网络安全靶场包含 CTF、MariaDB、Redis 缓存、Frp Server、Frp Client 共 5 个容器组件。其中，容器 CTF 即网络安全靶场平台网站；用户的个人信息和答题信息等存储到 MariaDB 容器中；缓存数据存储到 Redis 容器中；Frp Client 与 Frp Server 容器通过 Frp 网络相互连接，用于反向代理 Web、Pwn 及仿真环境这 3 种类型的动态靶机。靶机控制开启销毁模块由 Python 脚本完成，通过网络安全靶场管理界面进行统一管理和控制。网络安全靶场容器架构如图 3 所示。

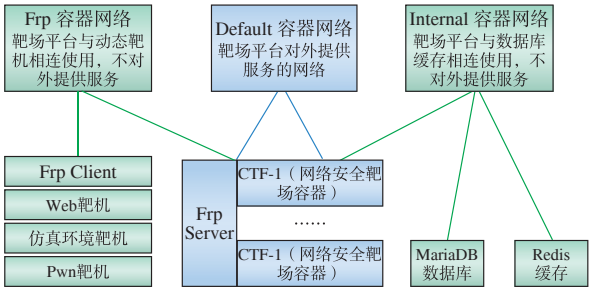

图3　网络安全靶场容器架构

Frp 网络、Internal 网络和 Default 网络都以 Bridge 桥接模式连接。其中，Internal 网络为容器内部通信网络，用于网络安全靶场与 MariaDB、Redis 缓存间的通信，不对外提供端口映射；Default 网络为网络安全靶场容器的 Web 界面所在网络，对外提供端口映射，可创建多个网络安全靶场容器，并使用 Nginx 做负载均衡及缓存；Frp 网络为 Frp Client 与 Frp Server 程序所使用，通过 Frp 程序的反向代理功能可将动态靶机通过 Default 容器网络对外提供端口映射。

2.2　Docker Swarm 集群

Docker Swarm 是 Docker 的集群管理工具，它的主要作用是把多个 Docker 主机作为一个整体来进行管理，通过一个入口管理多个 Docker 主机上的资源[8]。任何安装 Docker 的主机都可以使用 Docker Swarm 功能快速扩展多个主机。网络安全靶场利用 Docker Swarm 的集群管理能力，能够将题目容器分发到不同的节点上运行。用户每次请求启动题目容器时，靶场将根据 Swarm 调度算法，选出适合的节点运行该题目容器。

2.3　动态独立靶机

网络安全靶场采用了动态独立靶机技术。每个动态独立靶机存在的时间可由参赛队伍进行设置，防止空闲靶机占用系统资源。靶机可随时延长时间或销毁，方便用户使用全新的环境进行测试。动态独立靶机通过 Frp 提供容器端口映射，服务端部署的 Frp Server 程序通过 Frp Client 应用程序接口，使用基本身份验证控制动态独立靶机端口，该程序能够安全、便捷地将动态独立靶机对外提供服务的 IP 暴露给用户。

3 靶场应用

本文设计的网络安全靶场已成功应用于中国铁路兰州局集团有限公司，取得的效果如下。

（1）在网络安全人才的培养选拔方面，该靶场已用于举办网络信息系统职业技能竞赛，有利于发掘网络安全人才、建立完善的网络安全人才培养体系。

（2）在网络安全日常培训方面，该靶场已用于开展日常网络安全理论知识学习、网络安全竞赛知识学习、网络安全渗透测试实战学习等，进一步提高了铁路网络信息系统相关技术人员网络安全技能和攻防技能。

（3）在仿真环境渗透测试方面，该靶场已用于构建部分业务应用系统运行环境并进行仿真测试，有利于预先发现网络安全隐患，降低测试成本。

4 结束语

本文设计了基于 Docker 技术的网络安全靶场，该靶场可用于日常的网络安全学习、竞赛、仿真环境渗透测试等，有助于铁路行业开展网络安全人才的培训选拔、内部攻防演习、网络安全日常培训等工作，进而为铁路网络安全管理提供技术支撑，为下一步开展铁路网络安全靶场体系构建提供参考。

参考文献

[1] 中华人民共和国国民经济和社会发展第十四个五年规划和2035年远景目标纲要[N]. 人民日报，2021-03-13（001）.

[2] 袁　胜. 加强信息技术产品高保障级测评，提升关键信息基础设施安全保障水平 [J]. 中国信息安全，2022（2）：72-75.

[3] 祝咏升，姚洪磊，崔伟健. 铁路网络安全靶场设计与研究 [J]. 铁路计算机应用，2021，30（8）：52-56.

[4] 程　静，雷　璟，袁雪芬. 国家网络靶场的建设与发展 [J]. 中国电子科学研究院学报，2014，9（5）：446-452.

[5] 方滨兴，贾　焰，李爱平，等. 网络空间靶场技术研究 [J]. 信息安全学报，2016，1（3）：1-9.

[6] 韩　挺，李　鑫，韩耀明. 网络空间安全靶场设计研究 [J]. 信息安全研究，2018，4（5）：430-432.

[7] 赵　千，李耀兵，江　浩，等. 网络靶场的建设现状、基本特点与发展思路 [J]. 中国信息化，2022（6）：62-64.

[8] 杨森森. Dockers容器群自动化部署系统研究与实现[D]. 郑州：郑州大学，2020.

责任编辑　朱　一